AURION ENTERPRISES

AI GOVERNANCE & DEFENSE SUITE | LAYER 3 OF 3

# AI Security & Verification

Armed Response for IT, built for South African SMMEs and the enterprises and funders that serve them

Business Proposal | Version 2.0

Prepared for: SMMEs, enterprises, public sector and ESD / DFI partners

Date: 26 October 2026

# 1. Executive summary

South African organisations are adopting AI agents and cloud tools faster than they can secure or govern them. At the same time the Information Regulator has moved from guidance to enforcement, and the average cost of a data breach in South Africa is reported at R44.1 million (IBM Cost of a Data Breach Report 2025). Small and medium enterprises cannot afford a security operations centre, yet they hold the same regulated personal information as large firms.

Aurion Enterprises proposes **AI Security & Verification**, the third layer of the Aurion AI Governance & Defense Suite. It is sold as an outcome, **"Armed Response for IT"**: affordable detection, a safe and scoped verification that confirms whether a threat is real, a remediation report, and a POPIA-aligned evidence pack, all measured against a baseline so the risk reduction can be shown in numbers.

> **The offer in one line: we do not just tell you something is wrong. We prove whether it is exploitable, fix it, and hand you the evidence your auditor, funder and regulator will ask for.**

## What changed in Version 2

Version 2 incorporates an independent analysis of adoption, service delivery and monitoring. The main changes are:

- Tier 1 is reframed as a **POPIA compliance baseline**, not alerts alone.
- Tier 3 no longer promises 24/7 cover until a SOC partner is contracted; it is sold as **extended-hours monitoring with on-call escalation**.
- A published **Verification Methodology Statement**, three **remediation modes** and a **Service Commitment Schedule** replace general wording.
- **Scope drift control** (a reconciliation check at every verification run) becomes a hard product requirement.
- Success is measured on **outcomes against a baseline**, with a funder dashboard, not on activity counts.
- A **Trust Pack** and an **Aurion Verified** standard give a new entrant credibility without customer logos.

## Where it sits in the suite

**LAYER 3 | AI Security & Verification**
Detect, verify and fix. This proposal.

**LAYER 2 | AI Agents Orchestration (Suite)**
Governed agents with Agent Passports.

**LAYER 1 | AI Assurance & Audit**
Assurance Register, audit trail, evidence.

Layer 1 produces the evidence trail. Layer 2 runs governed AI agents (each carrying an Agent Passport). Layer 3 defends the environment those agents and the business run on, and verifies that defences work. Each layer can be bought alone; together they give a single governed, defended and auditable AI estate.

# 2. International industry dynamics

Three global shifts make the case for a verified, managed security service aimed at smaller organisations.

## 2.1 Managed detection and response is the fastest-growing part of security services

Analyst estimates of the global MDR market differ by method and scope, but all point the same way: 2026 market value is estimated between roughly USD 2.8 billion and USD 6.3 billion, with annual growth forecasts of about 18% to 25% into the early 2030s. Cloud-delivered MDR holds the large majority of the market, and endpoint-led MDR is the biggest segment. Buyers are choosing managed outcomes over tools because of the global shortage of security staff.

| Source (2026 estimate) | 2026 size | Forecast | Growth (CAGR) |
|---|---|---|---|
| Fortune Business Insights | USD 2.81 bn | USD 10.43 bn by 2034 | 17.8% |
| The Business Research Company | USD 4.16 bn | n/a | 20.3% |
| MarketsandMarkets | USD 6.28 bn | USD 19.01 bn by 2031 | 24.8% |
| GII Research | USD 6.25 bn | USD 20.94 bn by 2032 | 22.2% |

Ranges reflect different definitions of the market. Aurion plans on the conservative end.

## 2.2 Services are overtaking software

Pure security software grows slowly while response and remediation services are expanding several times faster. The commercial lesson is to bundle detection cheaply and charge for the fix and the proof. Competing on price alone loses to larger vendors; competing on verified outcomes does not.

## 2.3 AI governance is becoming a trade requirement

The EU AI Act classifies AI systems by risk and places documentation, logging, human-oversight and risk-management duties on high-risk systems. It can apply to non-EU companies whose AI is used in the EU. Timelines for high-risk obligations have been subject to a proposed extension (the EU Digital Omnibus), so readers should confirm current dates before relying on them. ISO/IEC 42001, the AI management system standard, is voluntary but is widely described as covering most of the organisational groundwork the Act expects. For South African exporters, suppliers to multinationals and DFI-funded firms, being able to show governance evidence is increasingly a condition of doing business.

## 2.4 Offensive security must be authorised, scoped and methodical

Internationally, verification and red-teaming services operate under signed rules of engagement, explicit asset lists and indemnities, and they publish their methods against recognised frameworks (PTES, MITRE ATT&CK, CIS Controls v8). Aurion adopts the same discipline from day one and makes it a visible part of the product (sections 5 and 6).

# 3. South African market analysis

## 3.1 Threat and cost picture

| Indicator | Figure | Source / note |
|---|---|---|
| Average cost of a data breach, South Africa (2025) | R44.1 million | IBM Cost of a Data Breach Report 2025, as reported by Business Report (7 July 2026) |
| Same measure, 2024 | R53.1 million | IBM 2024; South Africa ranked 14th most expensive of 16 countries studied |
| Reported data breaches, 2025/26 financial year | 3,219 | Cube ICT Solutions, via Business Report |
| Estimated economic drag of breaches | R142 billion a year (up to 1.81% of GDP) | Cube ICT Solutions estimate; indicative |
| Security compromises reported to the Regulator since 2021 | Over 8,000 | Information Regulator briefing, 31 Aug 2026 |

IBM figures are large-organisation benchmarks. For an SMME the absolute loss is smaller but proportionally existential: downtime, lost customers and legal exposure can end a business.

## 3.2 Regulation is now enforced

- The Information Regulator opened a compliance monitoring exercise at the end of 2025, sending formal notices to many organisations to demonstrate POPIA compliance.
- In its 31 August 2026 briefing it reported the largest fines to date (R5 million each against the Departments of Justice and of Basic Education). The Basic Education notices were set aside on appeal, which shows both that the Regulator will act and that process matters.
- Administrative fines of up to R10 million are available, and the Regulator is considering amendments that would allow immediate fines without a compliance window.
- 2026 enforcement notices (for example against a public TVET college) cited basic failures such as an unregistered Information Officer and no compliance framework on file. Small, well-documented controls matter, which is why Tier 1 is built as a compliance baseline.

## 3.3 Local pricing anchors

Standard managed IT support for SMMEs in South Africa typically runs from about R180 to R400 per user per month, and small-business all-in IT and security packages are commonly priced from about R5,000 to R12,500 per month. Local AI-receptionist vendors publish entry prices in roughly the R850 to R1,450 per month range. SMME buyers expect a visible starting price, so Aurion publishes firm pilot prices rather than "proposal only" pricing.

## 3.4 Competitive position

| Competitor type | Strength | Gap Aurion fills |
|---|---|---|
| Local MSPs (IT support) | Relationship, on-site help, low price | Little verification or compliance evidence; reactive |
| Global endpoint vendors | Strong detection tooling | Complex for a 10-person firm; no local compliance report |
| SOC / MDR specialists | Human monitoring | Priced for mid-market and up; not packaged for SMMEs |
| Local AI-agent vendors | Published prices, quick start | Typically do not lead with a governance register or auditor-ready trail |

# 4. The proposition: Armed Response for IT

South African business owners understand armed response. A lock (the firewall) keeps honest people out; armed response is the team that arrives when the alarm trips. Aurion packages detection, verified response and compliance evidence in the same way: a monthly fee, clear scope, and a named response.

**TIER 1 Compliance Baseline**
Detect + attest

**TIER 2 Response Team**
Detect + verify + fix

**TIER 3 Extended-Hours SOC**
Verify + 06:00-22:00 + on-call

| | Tier 1: Essential (Compliance Baseline) | Tier 2: Advanced (Response Team) | Tier 3: Complete (Extended-Hours SOC) |
|---|---|---|---|
| Best for | Price-sensitive SMMEs, 5 to 20 staff | SMMEs holding sensitive data: accountants, clinics, law and engineering firms | Growing SMMEs (30+ users), high transaction volumes, supplier cohorts |
| Includes | AI-driven endpoint protection and alerts, **plus a POPIA security-safeguards checklist and monthly attestation** | Tier 1 plus hosted AI verification (safe, scoped), remediation in Advisory or Guided mode, and a Verification Report | Tier 2 plus **extended-hours monitoring (06:00 to 22:00 SAST) with on-call escalation**, Managed remediation within scope, and backup and recovery advisory |
| Compliance output | Monthly attestation and summary | Quarterly POPIA-aligned pack and Verification Report | Quarterly pack, incident evidence pack and executive briefing |
| Pilot price (excl. VAT) | R100 to R200 per user per month, or inside an all-in package of R5,000 to R12,500 per month | R250 to R450 per user per month, with a minimum seat count | R450 to R800 per user per month, with a minimum |
| Aurion margin logic | Cheap acquisition tier; differentiated on outcome (attestation), not tooling | Highest value-to-cost: low marginal cost per verification run | Margin depends on SOC partner terms; sold only once the partner SLA is signed |

## Pricing commitment

- Final pilot prices for Tier 1 and Tier 2 are fixed before launch, published, and **honoured for 12 months** for the pilot cohort. The ranges above are the band within which they will be set.
- **Excluded unless quoted separately:** incident-response hours beyond the plan allowance, third-party and cloud assets without the provider's written consent, hardware, and Managed remediation outside Tier 3.
- **Tier 3 24/7 cover** is not sold until a white-label SOC partner is contracted and a back-to-back SLA is signed. Until then Tier 3 is extended-hours with on-call escalation. Once the partner is in place, the tier can be upgraded to 24/7 and re-priced.

Prices are in rand. Exchange-rate movements affect tooling and wholesale SOC costs and are handled through an annual review clause after the first 12 months.

# 5. The differentiator: verified outcomes

Most small-business security products end at an alert. Aurion's Tier 2 and Tier 3 continue through a five-step loop:

| Step | What happens | What the client receives |
|---|---|---|
| 1. Detect | Endpoint tooling raises an alert | Plain-language notice, severity and affected asset |
| 2. Verify | Hosted verification runs a safe, scoped test on listed assets only, after a scope reconciliation check | Confirmation: real weakness, or false alarm |
| 3. Fix | Remediation in the mode agreed (see 5.2) | Ticket, change record and status |
| 4. Prove | Re-test after the fix | Verification Report: proof the hole is closed |
| 5. Record | Event, decision and approver logged in the Layer 1 Assurance Register | Auditor-ready trail and quarterly POPIA-aligned pack |

## 5.1 Verification Methodology Statement

The method is published so buyers and counsel know exactly what is and is not done. It is aligned to CIS Controls v8, PTES and a MITRE ATT&CK mapping.

| In scope (tested) | Out of scope (never done) |
|---|---|
| Exposed and public-facing services | Exploit chaining or lateral movement beyond the listed asset |
| Misconfigurations | Data exfiltration or copying of personal information |
| Credential hygiene and password policy | Denial-of-service or load testing |
| Patch status | Social engineering of staff, unless separately authorised in writing |
| Multi-factor authentication gaps | Any asset not on the signed Scope Schedule |

Tooling categories used are disclosed in the Trust Pack (vulnerability scanning, configuration assessment, identity checks, attack-path simulation in non-destructive mode).

## 5.2 Three remediation modes

| Mode | Who does the work | Default tier | Pricing |
|---|---|---|---|
| Advisory | Client's own MSP or staff fix; Aurion verifies and re-tests | Tier 2 | Included |
| Guided | Aurion provides a runbook; client executes; Aurion re-tests | Tier 2 | Included up to a monthly cap; hours above cap quoted |
| Managed | Aurion executes the fix within the signed scope | Tier 3 | Included up to a monthly allowance; priced per hour above it |

## 5.3 Service Commitment Schedule

Failure behaviour is operational, not aspirational. The Schedule below is issued with every contract. The time targets are proposed starting values to be confirmed in the pilot.

| Priority | Definition | Acknowledge | Verify | Escalation |
|---|---|---|---|---|
| P1 Critical | Active compromise or exposed critical asset | 15 minutes | 4 hours | Named on-call lead, then Aurion director; client contact called, not emailed |
| P2 High | Confirmed serious weakness, no active attack | 1 hour | 1 business day | Named analyst, then Aurion lead |
| P3 Normal | Moderate or low finding | 1 business day | Next monthly cycle | Ticket owner |

**When we cannot verify.** If an alert cannot be verified within target, it is escalated to a named human and the client is told in plain language what is known and unknown. It is never closed silently. A post-incident review is delivered after every P1 within 10 business days. Every action on a client asset is logged with who approved it and when, and clients are always told when an automated process was involved.

## 5.4 Onboarding standard

- **One-page Scope Schedule** with pre-approved asset categories (for example, "all endpoints on the supplied asset register"), a named client contact and kill-switch contact, and test windows.
- **Minimum asset register** covering endpoints, identities, cloud tenants and public-facing services, with a **coverage attestation** the client signs, so both parties know what is and is not protected.
- **Standard POPIA operator agreement** and data-processing schedule in the onboarding pack, so SMMEs do not have to draft their own.
- **Guided onboarding** and a Tier 1 to Tier 2 upgrade path that pre-populates the Scope Schedule from Tier 1 telemetry.
- **Baseline assessment** at onboarding (CIS Controls IG1 coverage and POPIA control-gap count), so improvement can be measured at exit.

## 5.5 How the three layers connect

**Shared evidence schema: one control-mapping table (POPIA section > control > evidence artefact)**

Client sees: Layer 2 agent inventory and status | Layer 3 findings, fixes and proofs | Layer 1 register and quarterly pack

Each layer has its own dashboard view; data flows are one-way writes to the register, not shared credentials.

A governed AI agent from Layer 2 (for example a front-of-house call agent with an Agent Passport listing owner, purpose, data touched and human checkpoints) is itself an asset that Layer 3 protects and tests. Every Layer 3 event is written to the Layer 1 Assurance Register. A shared evidence schema, initially a simple control-mapping table and later a standard such as OSCAL, keeps the three layers consistent.

# 6. Legal safeguards: scope, authorisation and indemnity

> **Offensive or simulated-attack testing without explicit written authorisation is unlawful. For SMMEs this is a legal minefield, so Aurion makes safety and legality part of the product.**

- **Tier 1** tooling is passive and detection-only.
- **Tier 2 and 3** verification activates only on assets the client has listed in a signed Scope Schedule.
- The contract carries **Scope Clauses**, rules of engagement, test windows and a client indemnity limited to listed assets.
- Third-party and cloud assets are excluded unless the owner or provider has also consented in writing.
- Verification is simulation-based and non-destructive by design; a kill switch and a named client contact are required before any run.
- Personal information seen during verification is processed under the standard POPIA operator agreement and kept to the minimum necessary.

## 6.1 Scope drift control (hard product requirement)

Scope drift is the largest legal risk in the model. A **scope reconciliation check** therefore runs automatically before every verification run:

- The live asset inventory is compared with the signed Scope Schedule.
- If an unlisted asset is found, the verification run **halts** and the client is asked to amend the schedule or exclude the asset in writing.
- The check and its result are logged in the Layer 1 Assurance Register.

Legal wording should be reviewed by qualified counsel before the pilot starts.

# 7. Business model and financial logic

| Driver | Approach |
|---|---|
| Revenue | Monthly recurring fees per user or device; optional once-off onboarding; incident response and Managed remediation hours above allowance |
| Cost of goods | Endpoint licences, hosted verification compute, extended-hours monitoring staff or partner wholesale (Tier 3), insurance and legal cover |
| Channel | Direct to SMMEs; cohort sponsorship through enterprise supplier-development programmes; DFI and ESD-funded cohorts |
| Margin protection | Do not discount on price alone. Sell the Verification Report, the compliance baseline and the Aurion Verified standard as the premium |
| Scale | One hosted verification platform serves all clients, so marginal cost per scan stays low as cohorts grow |

# 8. Monitoring, assurance and metrics

The pilot is built to produce outcome evidence, not activity counts. Funders and enterprises renew on measured change.

## 8.1 Outcome metrics against a baseline

| Metric | What it shows |
|---|---|
| % of critical findings closed within SLA | Whether risk is actually being removed |
| Mean time to verify (MTTV) and mean time to remediate (MTTR) | Speed of the loop from alert to proof |
| CIS Controls IG1 coverage % and POPIA control-gap count (baseline vs. exit) | Risk-score trend and the core funder deliverable |
| % of assets with verified controls | Coverage quality, not just coverage |
| Audit findings avoided or passed | Business and regulatory benefit |

## 8.2 Service health (the service monitors itself)

The platform is instrumented for alert-to-verification latency, false-positive rate, false-negative sampling (periodic re-testing of assets reported clean), verification success rate and client-reported issues. A monthly **service health summary** is sent to each client.

## 8.3 Three-tier reporting model

| Cadence | Content | Format and channel |
|---|---|---|
| Real time | Alert notifications by priority | Phone call for P1; app or email for P2 and P3 |
| Monthly | Operational summary: tickets, verifications, fixes; service health; Tier 1 attestation | PDF plus register export |
| Quarterly | POPIA-aligned compliance pack and Verification Report; baseline-to-date delta | PDF plus register export; executive briefing for Tier 3 |

## 8.4 Regulatory mapping and horizon scanning

Reports are generated from a control-mapping table (POPIA section to control to evidence artefact, for example POPIA ss 19 to 22 mapped to CIS Controls and to logged evidence). When the Regulator or the EU AI Act timelines change, the report regenerates instead of being rewritten. A **named owner** performs a quarterly legal horizon scan covering POPIA amendments, Information Regulator notices and the EU AI Act timeline.

## 8.5 Early-warning indicators for retention

Retention is tracked ahead of time through report log-ins, verification runs per asset, remediation ticket closure rate, NPS at 30, 60 and 90 days, and support-ticket volume. Accounts with declining engagement receive proactive outreach.

## 8.6 Independent assurance of Aurion's own claims

Verification reports are otherwise self-attested, so Aurion commits to build external assurance: a published security whitepaper on Aurion's own controls; an external penetration test of the Aurion platform with a published summary; and a roadmap towards ISO/IEC 27001 and a SOC 2 Type I report. Dates for these milestones are to be set by Aurion leadership and published in the Trust Pack.

# 9. Trust Pack and Aurion Verified

A new entrant has no customer logos, so credibility is built from evidence the buyer can inspect before signing.

## 9.1 The Trust Pack (one downloadable bundle)

- Redacted sample Verification Report and redacted sample Assurance Register entry
- Verification Methodology Statement and Service Commitment Schedule
- One-page Scope Schedule template and minimum asset register template
- Standard POPIA operator agreement and data-processing schedule
- Security whitepaper, and a "how we fail safely" page
- Procurement documents: B-BBEE credentials, insurance certificates, company registration
- Founder credentials and advisory board, and a named security partner or accreditation where available

## 9.2 The Aurion Verified standard

A client-facing badge with published criteria: all listed assets verified, no critical open findings, and the quarterly report delivered. It gives SMMEs a signal when selling to enterprises, and gives funders and procurement teams a consistent test.

# 10. Go-to-market: one document, two audiences

## For SMMEs

- Lead with outcome and price: "Armed Response for IT", with the published pilot price.
- **Primary lead magnet:** a free, self-service POPIA and security-posture quiz (about 60 seconds) that returns a redacted sample report and a Tier recommendation. The full report is released after a demo booking.
- First-cohort programme: the first 10 deployments receive founder-level onboarding and a published case study with numbers. If there are no customers yet, say so; honest stage-setting beats invented logos.

## For enterprises and the public sector

- **Cohort sponsorship package**: for example 10 SMMEs at a fixed price with a quarterly risk-reduction report, designed so an ESD manager can procure it without a new vendor process. Price to be set before launch.
- Procurement-ready documentation from the Trust Pack (B-BBEE, operator agreement, insurance).
- Where AI-governance evidence is needed for EU or multinational customers, link Layers 1 to 3 to ISO/IEC 42001-style documentation.

## For ESD / DFI funders

- **Funder dashboard**, scoped into the pilot: baseline vs. current risk score, incidents verified and closed, compliance-readiness %, and anonymised per-SMME trend lines.

# 11. Pilot plan and success measures

| Phase | Timing | Activities | Measures |
|---|---|---|---|
| Prepare | Weeks 1 to 8 | Trust Pack; Verification Methodology Statement; scope reconciliation build; templates and counsel review; Tier 3 partner decision | Signed templates; control map complete; Tier 3 re-scoped or partner signed |
| Pilot | Months 3 to 5 | Onboard 10 to 20 SMMEs on Tiers 1 and 2 with baseline assessments; publish redacted proof assets | Baseline captured for every client; MTTV; MTTR |
| Prove | Months 6 to 7 | Exit assessment; delta vs. baseline; case study with numbers; test Tier 3 | Risk-score delta; retention; NPS at 30/60/90 days |
| Scale | Month 8 onwards | Open cohort sponsorship to enterprises and funders | Recurring revenue; margin per tier |

# 12. Priority actions (next 30 to 60 days)

| # | Action | Owner | Why |
|---|---|---|---|
| 1 | Publish the Trust Pack (sample report, methodology, templates) | Product + Legal | Unblocks adoption; substitutes for missing customer logos |
| 2 | Verification Methodology Statement and control mapping | Security lead | Makes verification concrete and defensible |
| 3 | Contract the Tier 3 SOC partner or re-scope to extended hours | Operations | Removes the weakest claim before pilot sales |
| 4 | Build baseline and delta measurement into onboarding | Product | Enables funder reporting and the case study |
| 5 | Implement scope reconciliation check at each run | Engineering + Legal | Closes the largest legal exposure |
| 6 | Finalise POPIA operator agreement and Scope Schedule templates | Legal | Removes onboarding friction |
| 7 | Make the 60-second risk check the primary lead magnet | Marketing | Improves pipeline conversion |

Owners are proposed roles; named individuals are to be assigned by Aurion leadership.

# 13. Key risks and mitigations

| Risk | Mitigation |
|---|---|
| Unauthorised or out-of-scope testing | Signed Scope Schedules, indemnity, kill switch, logged approvals, halt-and-amend scope reconciliation at every run |
| Over-promising on Tier 3 cover | No 24/7 claim until SOC partner and back-to-back SLA are signed; extended-hours wording until then |
| Price pressure from larger vendors and MSPs | Sell the compliance baseline, Verification Report and Aurion Verified; avoid price-only competition |
| Dependence on third-party tooling and SOC partner | Dual-source where possible; contractual service levels; exit clauses |
| Currency movement on USD-priced tools | Rand-denominated contracts; annual review clause after the 12-month price lock |
| Weak early social proof | Trust Pack, first-cohort offer, honest stage messaging, early case study with numbers |
| Self-attested verification | External penetration test of Aurion platform; ISO/IEC 27001 and SOC 2 Type I roadmap |
| Regulatory change (POPIA amendments, AI rules) | Named owner, quarterly horizon scan, reports regenerated from the control map |

# 14. Next steps

- Agree the pilot cohort and sponsor (enterprise, public body or funder).
- Decide and publish firm Tier 1 and Tier 2 pilot prices, and the cohort sponsorship price.
- Decide the Tier 3 route: contract the SOC partner, or launch as extended-hours.
- Set dated milestones for the security whitepaper, external penetration test and ISO/IEC 27001 roadmap.
- Prepare the Trust Pack and have counsel review the legal templates.
- Schedule a 20-minute sizing call to place each SMME in Tier 1, 2 or 3.

## Sources and notes

IBM Cost of a Data Breach Report 2024 and 2025 (South Africa figures as reported by ITWeb, TechCentral and Business Report, 2024 to July 2026). Cube ICT Solutions estimates via Business Report, 7 July 2026. Information Regulator media briefing of 31 August 2026 and enforcement notices of May and June 2026, as reported by Werksmans, Bowmans, Michalsons and BusinessTech. MDR market estimates from Fortune Business Insights, The Business Research Company, MarketsandMarkets and GII Research (2026 editions). EU AI Act and ISO/IEC 42001 mapping from Cloud Security Alliance (May 2026) and SureCloud. Version 2 service design, metrics and pilot changes follow the independent "Analysis & Recommendations: Aurion Layer 3". Local pricing anchors, response-time targets and tier model are planning values to be validated in the pilot. Market-research figures are third-party estimates and are indicative only.

This document is a business proposal, not legal or financial advice.